Flag 14 of 18: Malicious Package Downloaded Before the API Query

Rogue Synthesis scenario · Cymbal Investments · Google SecOps SIEM

Question

What package was downloaded immediately prior to the API query?

Answer

SyntaxOptimizer-2.1.4.vsix

Evidence

Zscaler proxy event, 20:18:26Z, user `alex.chen`, host IP `10.240.12.80`, application Visual Studio Code:

- `target.url`: `https://marketplace.visualstudio.com.cdn-cache.net/extensions/DevTools/SyntaxOptimizer/2.1.4/SyntaxOptimizer-2.1.4.vsix`
- Method `GET`, response `200`, user agent `VSCode/1.89.1`.
- The domain is a lookalike: the real name `marketplace.visualstudio.com` is used as a prefix on the attacker domain `cdn-cache.net`. It resolved to a Microsoft address (`13.107.246.10`), so the IP alone would not have raised an alarm.
- The referer was the real marketplace page `https://marketplace.visualstudio.com/items?itemName=DevTools.SyntaxOptimizer`.
- It came about 5.5 minutes before the Gemini API call at 20:23:56Z. VS Code extensions run on Node.js, which explains the `node-fetch` user agent.

How it was found

Window: Oct 15 19:30 to 20:24 UTC. A search of alex.chen web traffic gave this sequence (list times, one hour ahead): `github.cymbal.corp`, `stackoverflow.com`, `copilot-proxy.githubusercontent.com`, the real marketplace, the lookalike marketplace, then the Gemini API.

```
principal.namespace = "Cymbal"
AND metadata.event_type = "NETWORK_HTTP"
AND (principal.user.userid = "alex.chen" OR principal.ip = "10.240.12.80")
```

Lesson

Work backward from the effect to its cause. Read the full domain name: a trusted name used as a prefix is a typosquat.

Next pivot

Look at what the extension launched on alex.chen workstation after the API call.